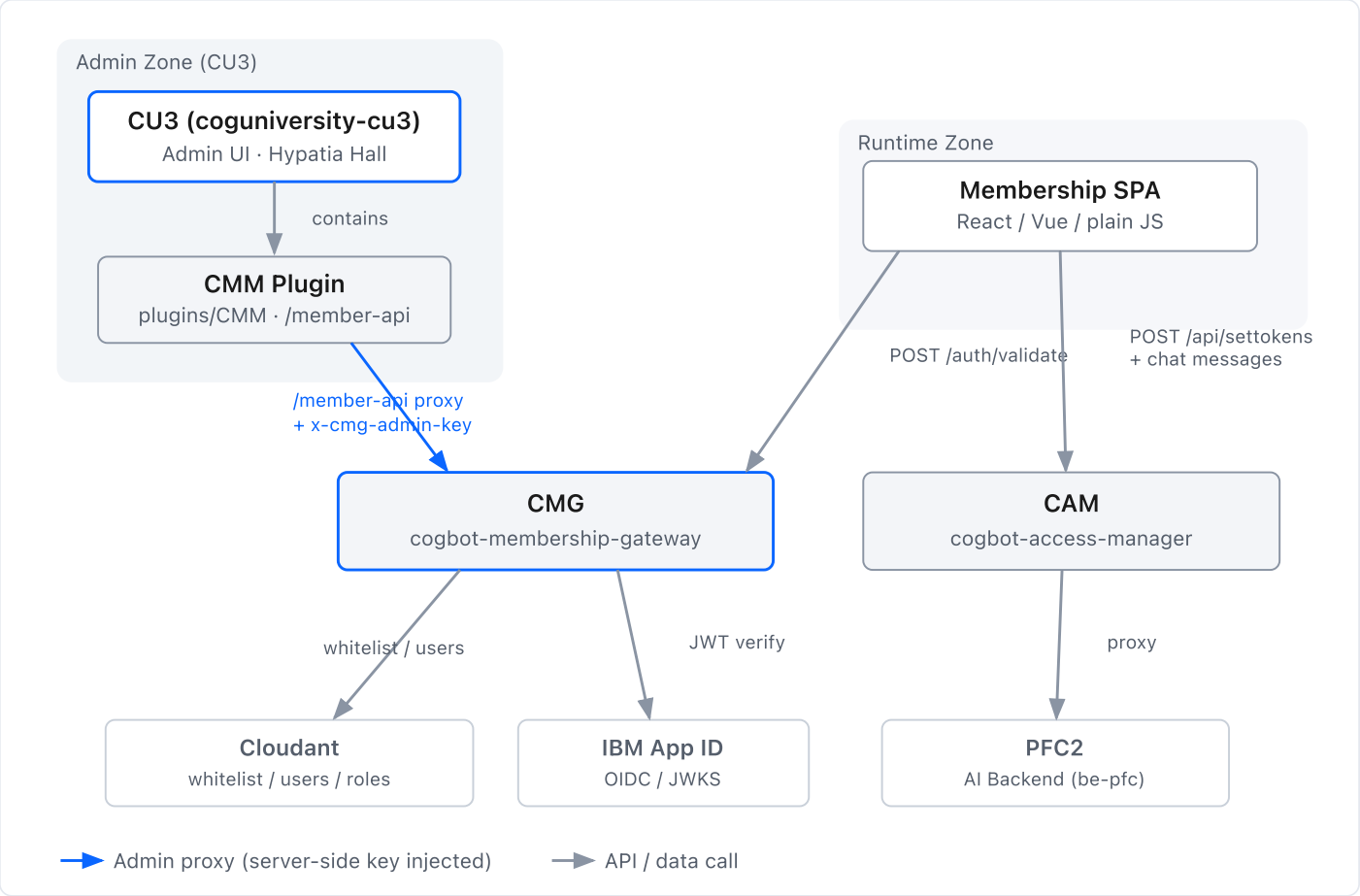
Access Management Architecture

How CU3's Administration building (Hypatia Hall — CMM plugin), the CogBot Membership Gateway (CMG), and the CogBot Access Manager (CAM) relate to each other.



How the Three Systems Fit Together

The Administration building (Hypatia Hall) in CU3 hosts the **CogBot Membership Manager (CMM)** — a React plugin giving platform admins a full CRUD UI over CMG's member database. CMM never calls CMG directly from the browser. Instead, `app.js` in CU3 mounts an HTTP reverse proxy at the `CMG_INSTANCE` path (e.g. `/member-api`) that forwards all traffic to `CMG_PROXY_TARGET` and automatically injects the `x-cmg-admin-key` header from the server environment — the key never reaches the browser.

At runtime a Membership SPA talks to **both** downstream services. It sends the App ID `idToken` to CMG (`POST /auth/validate`) to verify membership, get roles, and run any geofence check. Then it sends the same token to CAM (`POST /api/settokens`) to establish a server-side chat session. All subsequent chat traffic flows through CAM, which injects Bearer (authenticated) or Basic (anonymous) credentials before forwarding to the PFC2 AI backend.

API Reference

CU3 → CMG (Admin)

CMM action	CMG endpoint
List members	`GET /admin/members`
Add member	`POST /admin/whitelist`
Edit member	`PUT /admin/members/:email`
Remove from site	`DELETE /admin/members/:email`
List roles	`GET /admin/roles`
Resolve namespace	`GET /admin/cogbot-namespace`
Clear geofence cache	`POST /admin/geofence/cache/clear`

SPA → CMG (Auth)

Purpose	CMG endpoint
Pre-login geofence check	`GET /auth/geofence/check`
Validate membership	`POST /auth/validate`
OIDC token exchange	`POST /auth/token`
Record login	`POST /auth/notify-login`
Health	`GET /health`

SPA → CAM (Chat)

Purpose	CAM endpoint
Establish session	`POST /api/settokens`
Get cogbot config	`GET /api/init/cogbots/:id`
Get user info	`GET /api/init/userInfo`
Get greeting	`GET /api/v1/init/greeting/:id`
Send message (JSON)	`POST /api/cogbots/*/message`
Send message (SSE)	`POST /api/cogbots/*/message/stream`
Log UI event	`POST /api/v1/logs/ui`

Key Design Decisions

CMG is the single source of truth for membership

Neither CU3 nor Membership SPAs touch Cloudant directly. CMG owns JWT verification (via App ID JWKS), whitelist lookup, role assignment, geofencing, and auto-provisioning. Geofence config is cached in-memory for 5 minutes; the CMM Refresh button flushes it instantly via the cache-clear endpoint.

CAM is stateful; CMG is stateless per request

CAM maintains a server-side session (PostgreSQL in production, in-memory in dev) keyed by a signed `cogbot-sid` cookie. CMG has no session state — it re-validates the App ID JWT on every `/auth/validate` call.

CU3 injects the admin key server-side

The `CMG_ADMIN_KEY` secret never reaches the browser. CU3's `app.js` adds `x-cmg-admin-key` to every `/member-api` request before forwarding to CMG. Admins can also authenticate via bearer token if their email is in CMG's `ADMIN_EMAILS` list.

Streaming is per-CAM-instance, not per-cogbot doc

When `STREAM_MESSAGES=true`, CAM injects `config.streaming: true` into the `/api/init/cogbots/:id` response. The same Cloudant cogbot document can serve a streaming membership SPA and a non-streaming public widget simultaneously — no Cloudant writes required.